

One Receipt

An end-to-end protocol that lets anyone
verify one generative-AI transaction —
across every interface, for every party —
and lets the person it touched challenge it.

*Two paths, one receipt — and now the receipt says
exactly what it proves, carries the challenge inside
it, and is graded by a stranger, never by us.*

Bob Rapp · Ken Johnston · with Claude

Status: for review — Ken and Bob, then the Review Circle

A profile on the standards that exist, contributed upstream; never issued by the Foundation

Source of truth: github.com/aigovops-foundation/One-ai-Receipt-aigovops-foundation

Every date verified 13 September 2026. Items marked "unverified" must not be printed publicly.

Appendix A is the core specification v0.2-draft, B the delta matrix, C the master plan with the twelve decisions. Per-claim sources are in the practice repo research memos.

A proposal for an end-to-end protocol that lets anyone verify one generative-AI transaction — across every interface, for every party.

Whitepaper review draft **v0.2** · AiGovOps Foundation · 14 September 2026 · Authors: Bob Rapp, Ken Johnston, with Claude · Status: **for review** (Ken and Bob; then the Review Circle; then the coalition's standards liaisons) · Supersedes v0.1 (13 September 2026), which stays in the **practice** repo as history.

What changed since v0.1, in one line: the paper now makes only bounded claims, describes the v0.2 specification in this repository rather than a sketch, uses its own OR-0...OR-5 evidence ladder instead of borrowing OVERT's AAL levels, replaces the complaint pointer with a contestability object, adds a privacy threat model and witnessing, separates four roles, and carries the coalition and funding plan alongside it.

Assumption stated up front: "UP Path" in the original brief is read as UiPath — founding contributor to, and first platform certified under, AIUC-1. Every claim below carries a source; items that could not be confirmed on 13 September 2026 are marked "unverified" and must not be printed publicly.

0. In one paragraph

Today a person can talk to an AI in a chat window, through an API, by voice, inside an IDE, through a browser extension, on a phone, or through another agent — and no party can later prove, without trusting the operator, what model answered, under which policy, on whose authority, with what checks, and whether the record was altered afterwards. Many bodies each hold one piece: ISO 42001 certifies the organisation, AIUC-1 certifies the agent quarterly, OVERT signs the decision, C2PA signs the file, SCITT gives the transparency log, AP2 signs the shopping mandate, OpenTelemetry names the fields, the EU AI Act says logs must exist. No widely adopted profile yet joins them into **one receipt per transaction that a stranger can verify offline and a person can challenge**. This paper proposes that receipt — content-free, signed, chained, interface-agnostic, with contestability inside it — as a *profile that sits on the standards that exist*, contributed upstream rather than issued by the Foundation, and governed so that no party that sells the runtime, runs the log, assesses, or insures also grades its own interest.

1. The eight seams

Verified against the current landscape (sources in §9):

- 1. No transaction identifier survives the interfaces.** Only China's labelling rules (in force 1 Sep 2025) require a per-output "content reference number". MCP's 2026-07-28 spec *removed* session ids; OpenTelemetry's `gen_ai.*` conventions are still "Development" and unsigned. No id follows chat → API → agent → extension → product.
- 2. Identity is split three ways and never bound.** Human (OIDC, W3C VC 2.0), workload (SPIFFE/WIMSE, `draft-klrc-aiagent-auth-03`), and agent/model (A2A signed Agent Cards; ITU FG-TIDA, first meeting Nov 2026). Nothing signs *human* + *agent* + *model version* + *tool* together at call time without a stable personal identifier.
- 3. Policy decisions are asserted, not attested.** ISO 42001, NIST AI RMF, CSA AICM v1.1 and EU Arts 9–14 say controls must exist; OVERT 1.1 specifies a per-action proof that a control ran — and OVERT has one vendor implementation, no registered Independent Attestation Provider, and no assessor registry yet. The EU's harmonised logging standard, prEN 18229-1, is at Enquiry stage.
- 4. Transparency logs have a transport but no AI payload.** RFC 9943 (SCITT architecture) and RFC 9942 (COSE receipts) were published June 2026; there is no registered SCITT statement profile for "AI inference / agent action". OVERT does not reference SCITT.
- 5. Provenance is bound to the asset, not the session.** C2PA 2.3 and IPTC 2025.1 describe what produced a *file*; free-form text, voice and code — most of what generative AI emits — carry nothing, and platforms strip manifests.
- 6. Audit rights stop at the organisation.** EU Art. 12/26(6) logs are for the provider, deployer and regulator; ISO 42006 accredits auditors of *management systems*; there is no "verify with a public key, offline" norm outside Sigstore and OVERT tooling.
- 7. Incidents are narrative.** Art. 73 templates, OECD AIM, AIID and the Frontier Model Forum's incident sharing accept prose; none takes a receipt hash or inclusion proof as the anchor. NYC Local Law 144's audit regime produced two complaints and no enforcement in two years — evidence that summaries without artefacts do not work.

8. Interfaces are uneven, and contestability is a footnote. Voice has no marking channel; coding agents have AGENTS.md (guidance); on-device AI has RATS (RFC 9334) but no AI profile; A2A puts authorisation out of scope by design; commerce protocols (AP2, Visa TAP, Mastercard Verifiable Intent, OpenAI/Stripe ACP) prove *who* transacted but not *what the model did* between intent and cart. And in every one of these, the right to notice, explanation, challenge, review and remedy (EU Art. 86, Colorado SB 26-189) has no machine-readable home keyed to the event.

2. What exists, in one table

LAYER	STANDARD (STEWARD, STATUS)	WHAT IT ANSWERS	WHAT IT CANNOT
Organisation	ISO/IEC 42001:2023 (+42005 impact, 42006 audit bodies); NIST AI RMF 1.0 + AI 600-1	Does the operator have a management system?	Anything about one transaction
Agent (periodic)	AIUC-1 (AIUC; quarterly releases, Jul 2026 current; six domains; third-party audit + quarterly adversarial testing; insurance-priced; UiPath, Intercom, Cursor, Harvey, ElevenLabs, KPMG certified)	Was this agent tested and insured this quarter?	Whether the certified controls ran on <i>your</i> call
Decision (runtime)	OVERT 1.1 (Glacis, 11 Jun 2026; six domains; AAL-1...4; IAP + Qualified Assessor defined, none registered)	Did a control execute on this action, signed and chained?	Cross-vendor adoption; SCITT/C2PA/OTel mapping; human mandate; contestability
Log	IETF SCITT RFC 9943 / RFC 9942 (Jun 2026); Sigstore Rekord v2 (Oct 2025)	Was the statement registered and unaltered?	What an AI statement should contain; who witnesses
Identity	W3C VC 2.0 / DID 1.1 CR; SPIFFE; draft-klrc-aiagent-auth ; OpenID AIIM CG; Cloudflare Web Bot Auth (operator only, forbids human binding)	Who is the human / workload / bot?	Binding all three to one act, privately
Mandate	Google AP2 (Sep 2025; Intent/Cart/Payment Mandates as VCs); Mastercard Verifiable Intent (Mar 2026); Visa TAP (RFC 9421 signatures); OpenAI/Stripe ACP (allowance tokens)	What did the human authorise the agent to buy?	Anything outside commerce; what the model did
Telemetry	OpenTelemetry GenAI semconv v1.42 (Development)	Field names for model, tokens, tools, agents	Signing; stability
Content	C2PA 2.3 (Feb 2026); IPTC 2025.1; EU Transparency Code (Jun 2026) + Art. 50 Guidelines (Jul 2026)	What produced this file?	Text/voice/code; the session
Supply chain	CycloneDX 1.7 ML-BOM; SPDX 3.0.1 AI profile; OpenSSF Model Signing 1.0	What is the model made of?	The transaction
Regulation	EU AI Act as amended by (EU) 2026/1744: Art. 12 logging, Art. 50 (live 2 Aug 2026), Annex III 2 Dec 2027, Art. 73 incidents, Art. 86 explanation; Colorado SB 26-189 (1 Jan 2027); Korea AI Basic Act (22 Jan 2026); China labelling (1 Sep 2025); California SB 942 (2 Aug 2026)	What must be logged, disclosed, explained, reported	A format; a verifier
Incidents	OECD AIM; AIID; AIAAIC; FMF incident sharing (May 2026); MIT tracker	What went wrong, in prose	Linkage to evidence
Confidential compute	Apple PCC (expanded to Google Cloud, Jun 2026); Google Confidential Space; Intel Trust Authority	Which binary ran, in which enclave	What it answered

3. The proposal

The normative text is **spec/ONE-RECEIPT-SPEC.md** in this repository; this section is the reading guide.

3.1 One receipt, one graph, ten predicates

A **receipt** is a content-free, signed statement about one *bounded event* — a request and its response, an agent action, a segment of a stream, a batch item, a review — chained into a transaction graph with an id, a root and parents, registered with a log, and carrying pointers and commitments (never payloads) to the evidence each stakeholder may later be entitled to see.

PREDICATE	BINDS	BUILT ON
transaction	how the event was cut: interface, boundary, segment, id carrier, delegation depth	interface profiles; streaming/voice batching rule
identity	human (pseudonym), operator, agent, model version, tools — bound to one event, never a stable personal id	OIDC/VC 2.0 by reference; SPIFFE / Web Bot Auth; A2A Agent Card; SPDX/CycloneDX ref
mandate	what the human or authority authorised, and whether the action stayed inside it	AP2 / Verifiable Intent / TAP / ACP unchanged; a plain-words rule for non-commerce
policy	which gate ran, which version, allow/constrain/hold/escalate/deny, which controls with which outcomes, human in the loop	UCID, OVERT, AIUC-1, AICM, ISO 42001, NIST RMF control ids
runtime	salted commitments to input and output, counts, environment attestation reference, OTel ids, child receipts	OTel GenAI attributes; RATS; MCP/A2A ids
provenance-disclosure	what left, how it was marked, whether the AI nature was disclosed, in which languages and formats	C2PA 2.3; Art. 50; China reference number
witness	the independent log, checkpoint, inclusion and consistency proofs, witnesses, equivocation status	RFC 9943/9942; RFC 6962
contestability	notice · explanation · challenge · human review with named authority · named remedies · collective redress	Art. 86; SB 26-189; the practice's gates
legal-evidence (optional)	jurisdiction profile, collection, custody, timestamp assurance, export manifest	eIDAS QTSA; FRE 901; CN online litigation
community-authority (extension)	collective authority, consent basis, use restrictions	CARE principles; drafted only with Indigenous partners

Envelope: canonical JSON (a full RFC 8785 canonicaliser and a CBOR profile are v0.3 gates), Ed25519 by default with ES256, ML-DSA-65 and a hybrid in the algorithm registry; countersignatures from log operators, witnesses, time authorities, reviewers and assessors; a manifest that declares every predicate present and gives a reason for every one omitted; a privacy profile on every receipt; a non-empty **limitations** list on every receipt. Registered as a **SCITT statement profile** so any RFC 9943 transparency service can hold it. One receipt id, one URL pattern (`.../r/<id>`), one offline verifier that reports the level it could substantiate next to the level the issuer claimed.

3.2 Interface profiles

Same envelope; what changes is how the id is carried and how the person sees it.

INTERFACE	ID CARRIER	THE PERSON SEES	NOTES
Chat / web	Response header + a visible "receipt" affordance	A link under every answer	The café's Wren Card pattern
API	AI-Receipt response header; request may carry AI-Mandate	The SDK prints it	Maps 1:1 to an OTel span
Voice	Spoken id on request; id in the transcript	"Say 'receipt'" → the aggregate receipt of the stream	Fills the channel Art. 50 admits is weak; streams batch per turn or window, never per token
Agent-to-agent	Message metadata; nested receipts per hop; a delegation receipt per hand-off	The root receipt for the human principal	MCP has no session id — the receipt graph is the session; a mandate never widens down the chain
IDE / coding agent	One-Receipt : git trailer	In the commit	Coding agents already sign commits
Embedded / phone	On-device receipt with environment evidence; uploads when online	Settings → receipts	RATS profile; environment-level only
Commerce	AP2 Cart Mandate hash in mandate	The merchant receipt cites it	Visa/Mastercard/ACP compatible; within_mandate: no is an honest record of a breach

3.3 Four roles — and the separation rule

- **Operator** (seller/deployer) issues receipts and keeps the salts.

- **Log operator** registers them — a different party from the operator above OR-2, with witnesses co-signing checkpoints so equivocation can be caught and frozen.
- **Assessor** verifies samples without content access — never the operator, the log operator, the runtime seller, or the underwriter of the system it assesses; methodology and negative findings public.
- **Registry steward** publishes keys, profiles, assessor and public-interest review records — never the sole long-term steward, never a party with a commercial interest in an issuer it lists.
- **Verifier** is anyone with the public key and, above OR-1, the log — no account, no vendor dashboard.

Assurance is an evidence ladder the verifier computes, not a badge the issuer claims: **OR-0** unverified export · **OR-1** issuer signed · **OR-2** operator logged · **OR-3** independently logged and witnessed · **OR-4** independently assessed · **OR-5** public-interest accountable. It deliberately does not borrow OVERT's AAL levels or any certification tier, and it says nothing about the AI system's quality. What it adds to the periodic world is the **certificate-to-receipt link**: a quarterly certificate (AIUC-1, ISO 42001) becomes checkable against per-call evidence — "you said control A006 exists; show me it ran on the calls that mattered."

3.4 What each party can now ask, and get

PARTY	QUESTION	ANSWERED BY
Buyer / deployer	Which model and policy version served this call? Did the certified control run? Can I keep six months of evidence without holding content, and take it with me when I switch vendors?	identity, policy, runtime, witness; the procurement profile
End user / affected person	Was I talking to an AI, run by whom? What did I authorise, and did the agent stay inside it? Where is the explanation this interaction owes me? Who reviews, with what authority, and what remedies are named?	identity, mandate, provenance-disclosure, contestability — and the challenge, review and remedy receipts that answer it in the same graph
Regulator	Is the vendor's claim traceable to production runs? Was the log altered after the incident? Can I inspect without trade secrets?	policy, runtime, witness; authorised opening of commitments as a review receipt; the regulator-view package
Civil society	Is this system in a public register, and does the receipt say so? Can an independent assessor verify a sample without the vendor's cooperation? Is there a challenge route keyed to the receipt id, and can a representative use it?	contestability (collective_redress), the assessor role, the Public Interest Council's binding review
Seller / vendor	Can I prove controls ran without exposing prompts or weights? Is human intent separated from my agent's identity so I am not liable for what I never authorised?	Content-free by design; mandate separates the human from the agent; per-call evidence a certificate cannot produce — and no claim about premiums until someone publishes the evidence

4. What it improves on

The AiGovOps Foundation. Beacon already signs Ed25519 over JCS with an append-only Merkle log and an offline `VERIFY.md`; Umbrella already compiles law to UCIDs and binds evidence to controls; Lantern already reads them; Replay and prompt-studio share the wire format. What the Foundation's receipt lacks is the *shape* — it is its own envelope, not a SCITT statement; it carries an OIDC subject and plain hashes where v0.2 requires a pseudonym and salted commitments; it has no `mandate`, no interface profiles, no witness, no contestability, no certificate link. `docs/ADOPTION.md` and `adapters/` give each project its delta and its version. The ladder maps rung-for-rung — a 100 reads a receipt, a 200 emits one from CI, a 300 registers a hold, a 400 verifies a stranger's offline — and gains 500 (witness and assess) and 600 (review with authority). The Foundation's own rule stands and is now in the spec: it issues no standard, grades no receipts, and is not the long-term registry, assessor qualifier or notary.

Glacis / OVERT. OVERT is the best-specified per-decision receipt in the field and this proposal keeps its control evidence intact as a control vocabulary and an extension. It improves on it in four ways OVERT's own crosswalks leave open: (1) a SCITT profile so any transparency service can hold OVERT receipts, not only Glacis's notary; (2) OTel, C2PA and AP2 mappings; (3) explicit human-mandate, disclosure and contestability predicates (OVERT scopes out truthfulness and user-facing obligations); (4) a governance separation — today the OVERT steward sells the runtime and would qualify the assessors, and no assessor or IAP is registered fourteen months after 1.0. The ask to Glacis: sign the Beacon profile; co-author the SCITT profile; join as a proposed inaugural technical contributor under the conflict rules; let the community's 400s form the first verification pool.

AIUC-1 and the insurance track. AIUC-1 is the strongest *periodic* certification — audited, adversarially re-tested quarterly, priced into cover — and its consortium (UiPath among the founding contributors) is the widest industry table. Its limits are structural: a certificate says the agent passed last quarter, not that control A006 ran on this call; the standard's editor also accredits auditors and underwrites the policy. One Receipt gives AIUC-1 what it cannot produce itself — per-call evidence that a certified control executed — and gives insurers a loss-adjustment artefact. The ask: an AIUC-1 requirement that certified agents emit receipts, and a control-id vocabulary shared with OVERT and UCID. This paper makes no claim about premiums; the playbook forbids one without independent published evidence.

5. Standards path and governance

1. **IETF SCITT** — an Internet-Draft "AI Transaction Statement Profile" (the envelope as the signed statement; RFC 9942 receipts as inclusion proofs; witness co-signatures). Co-authors sought from Glacis, the SCITT editors, and one log operator.
2. **OVERT** — a registered profile `one-receipt.v0` under Agentic-Extended scope; Beacon's `aigovops-beacon.v1` conforms to it.
3. **OpenTelemetry** — a mapping table `gen_ai.*` ↔ predicate fields, submitted to the semantic-conventions-genai repo.
4. **C2PA** — an assertion type carrying the receipt id, so a signed file points back to the event.
5. **AP2 / Mastercard Verifiable Intent** — the `mandate` slot accepts their credentials unchanged; test vectors from their samples.
6. **NIST AI Agent Standards Initiative / NCCoE** — the interface-profile matrix as a public-interest use-case submission; **ITU FG-TIDA** (Nov 2026) for the identity binding.
7. **EU** — feed the six-month retention and content-free pattern into the prEN 18229-1 (Art. 12 logging) enquiry; propose the receipt id as the Art. 73 incident anchor; the contestability object as the Art. 86 evidence shape.

Governance is the Global One Receipt Collaborative (`governance/`): a Technical Incubator, a paid Public Interest Council with binding review, an Adoption and Pilot Network, an Independent Appeals Panel and a Standards Liaison Forum; funding caps (no contributor above 15%, no sector above 35%, at least 20% for paid public-interest participation, at least 20% for independent research); at least half of non-vendor seats outside North America and the EU; royalty-free IPR; vectors and the reference verifier in the open; and a founding cohort of 18–24 balanced parties invited in the playbook's order — standards communities and public-interest partners before vendors.

6. Ninety days for the Foundation

- **Weeks 1–3:** decisions taken; this repository public; Beacon emits v0.2 behind a flag from its existing signer; the ten corpus vectors chosen.
- **Weeks 4–6:** Lantern shows claimed vs verified; the café's Wren Card carries a receipt id; the 200 and 400 worksheets gain their receipt steps.
- **Weeks 7–9:** the Glacis note with the delta matrix; the SCITT -00 outline; the NIST submission; a Thursday devoted to a stranger verifying a receipt offline.
- **Weeks 10–13:** first external verification by a 400; the joint story; v0.2.1 with what broke; the first listening invitations out in order.

7. Risks and open questions

Salted commitments are the privacy floor, but content-free is not anonymous: graph shape, timing and counts leak, and the spec says so. A hash cannot explain — the contestability object must be honoured or Art. 86 is unmet. Streams need the batching rule and a closing aggregate, and the rule must hold for voice. On-device and TEE evidence is environment-level, not answer-level; the paper does not claim otherwise. zkML proof-of-inference (Lagrange DeepProve, EZKL) is not viable per request at frontier scale in 2026. A witnessed log can still be attacked by collusion between operator and witnesses — hence the requirement for more than one independent route above OR-2. The legal-evidence profile describes what was done; a court decides what it accepts. Adoption will follow procurement clauses, not goodwill — the EU model contractual clauses (MCC-AI, Mar 2025) and buyer evidence-rights templates are the levers. And the Foundation must not become the thing it warns against: it implements and teaches; it does not grade its own receipts.

8. Decisions for Ken and Bob

The twelve executive decisions are in `docs/MASTER-PLAN.md` §16. The four from v0.1 survive as decisions 1, 4, 5 and 8: the name; when to send the Glacis ask; who hosts the working group; which ten corpus cases become the first vectors (twelve are seeded).

9. Sources (selected; full memos in the practice repo, `docs/reference/research/`)

OVERT 1.1 standard, conformance and crosswalks (overt.is); Glacis docs and verifier (docs.glacis.io, verify.glacis.io); GeekWire on Glacis (7 Apr 2026); AIUC-1 site and changelog (aiuc-1.com); UiPath AIUC-1 announcements (19 Nov 2025; 9 Mar 2026); RFC 9943, RFC 9942, RFC 9901, RFC 9421, RFC 6962, RFC 8785; draft-klrc-aiagent-auth-03; draft-meunier-web-bot-auth-architecture-05; Regulation (EU) 2026/1744 and law-firm summaries (White & Case, Orrick, Gibson Dunn); AI Act Explorer Arts 12, 14, 50, 71, 73, 78, 86; Commission Transparency Code (10 Jun 2026) and Guidelines (20 Jul 2026); KLA JTC 21 tracker (prEN 18229-1); C2PA 2.3 spec; IPTC 2025.1; Google AP2 announcement; Visa Trusted Agent Protocol; Mastercard Verifiable Intent (PYMNTS, 5 Mar 2026); OpenAI ACP delegated payment spec; Cloudflare Web Bot Auth; Linux Foundation AAIIF and A2A releases; MCP spec 2026-07-28; OpenTelemetry semconv 1.41/1.42; CSA AICM v1.1; MITRE ATLAS v2026.08; OWASP Agentic Top 10 (2026); NIST AI Agent Standards Initiative; NCCoE agent identity concept paper; ITU FG-TIDA; NY State Comptroller audit of Local Law 144 (2 Dec 2025); Colorado SB 26-189; Korea AI Basic Act (Cooley); China labelling measures (China Law Translate); Ada Lovelace *Code & Conduct*; Apple PCC expansion (8 Jun 2026); Lagrange DeepProve-1; Attested Intelligence AGA; CARE Principles for Indigenous Data Governance (GIDA).

How to read this. Every date was checked on 13 September 2026; the sources live in the practice repo research memos. Anything marked **unverified** must not print publicly. Appendix A is the specification, B the delta matrix, C the plan — Appendix C §16 is the part that needs a yes.

One Receipt — Core Specification

Version: 0.2-draft · **Status:** incubation draft, not a standard · **Editor of record:** AiGovOps Foundation Technical Incubator (neutral convener; not the long-term sole editor, registry, assessor qualifier or trust root) · **Licence:** CC BY 4.0 (text), Apache-2.0 (schemas and code)

The key words MUST, MUST NOT, SHOULD, SHOULD NOT and MAY are to be read as in RFC 2119 / RFC 8174.

0. Scope and bounded claims

One Receipt defines one signed, content-free statement — a **receipt** — about one **bounded AI transaction event**, and the rules by which a stranger can verify it offline, chain it to the other events of the same transaction, register it with an independent log, and use it to notice, understand, challenge and remedy the outcome.

A verified receipt proves exactly this:

An identified issuer signed the declared claims, bound them to identifiers and time, and supplied the evidence the claimed assurance level requires.

It does **not** prove that the AI output was true, fair, safe, lawful, accurate, unbiased or harmless; that human review was meaningful; that a policy was well-designed; that a system is certified; that evidence is admissible; or that any insurance, regulatory or contractual consequence follows. Every receipt carries a non-empty `limitations` array and every verifier result repeats it. Text that claims otherwise is non-conformant marketing, not a receipt.

One Receipt does not replace existing standards. It profiles and connects them: transparency registration follows IETF SCITT (RFC 9943, RFC 9942); decision evidence maps to OVERT; telemetry names map to OpenTelemetry GenAI conventions; asset provenance maps to C2PA; commerce mandates are accepted unchanged from AP2 and Mastercard Verifiable Intent; control identifiers may come from UCID, OVERT, AIUC-1, CSA AICM, ISO/IEC 42001 or NIST AI RMF. Section 14 and `spec/delta-matrix.md` hold the mappings; none is normative for the other body until that body accepts it.

1. Terms

- **Transaction** — a run of related events with one `transaction_id`: a chat turn and its tool calls, an agent task and its delegations, a batch decision run, a challenge and its review.
- **Event** — one bounded observation inside a transaction (an inference, a tool call, a delegation hop, a human review, an output delivery, a policy decision, a challenge, a review, a remedy, an incident, or an aggregate of segments). One event may be described by several receipts from different issuers; they share `event_id`.
- **Receipt** — one signed envelope about one event, from one issuer, at one assurance level.
- **Predicate** — a versioned, typed group of claims inside a receipt. Ten are defined here; others may be registered.
- **Issuer** — the party whose key signs the receipt, acting in one **role** (§9).
- **Log operator** — the party that registers receipts in an append-only, verifiable log and publishes checkpoints.
- **Witness** — an independent party that co-signs log checkpoints so equivocation (showing different logs to different verifiers) can be detected.
- **Assessor** — an independent party that samples and verifies receipts and the controls behind them, without content access.
- **Registry steward** — the party that publishes key discovery, profile, assessor and public-interest review records a receipt points to.
- **Verifier** — anyone holding a receipt, a public key and, above OR-1, log access. No account, no network and no operator cooperation is required at OR-1.
- **Commitment** — a salted or keyed digest of content the receipt never carries. A plain hash of guessable content is not a commitment (§5).

2. The envelope

The normative schema is `spec/schema/one-receipt-envelope.schema.json`; predicates live under `spec/schema/predicates/`. The JSON form below is the reference serialisation; a CBOR form using the same field names is permitted when `signature.canonicalization` is `CBOR-CDE`.

FIELD	TYPE	RULE
<code>spec_version</code>	const "0.2-draft"	Verifiers MUST reject unknown versions rather than guess.
<code>receipt_id</code>	URN <code>urn:one-receipt:...</code>	Unique per receipt.
<code>transaction_id</code>	URN	Shared by every event of one transaction.
<code>event_id</code>	URN	Shared by every receipt about the same observed event.
<code>parent_receipt_ids</code>	URN[]	Zero for a root; one or more otherwise. A receipt MUST NOT list itself.
<code>root_receipt_id</code>	URN	Equals <code>receipt_id</code> when <code>parent_receipt_ids</code> is empty.
<code>transaction_type</code>	enum	<code>inference</code> , <code>tool-call</code> , <code>agent-delegation</code> , <code>human-review</code> , <code>output-delivery</code> , <code>policy-decision</code> , <code>challenge</code> , <code>review</code> , <code>remedy</code> , <code>incident</code> , <code>aggregate</code> .
<code>sequence</code>	integer ≥ 0	Position among receipts of the same issuer role within one transaction.
<code>boundary</code>	enum	<code>request-response</code> , <code>streaming-segment</code> , <code>agent-action</code> , <code>batch</code> , <code>aggregate</code> (§3).
<code>started_at</code> / <code>ended_at</code> / <code>issued_at</code>	RFC 3339	<code>started_at ≤ ended_at ≤ issued_at</code> MUST hold.
<code>clock_source</code>	enum	<code>issuer</code> , <code>trusted-time-authority</code> , <code>qualified-time-stamp</code> . Issuer clocks are unverified assertions.
<code>issuer</code>	object	<code>id</code> , <code>key_id</code> , <code>role</code> (§9), optional <code>key_discovery</code> .
<code>assurance_level</code>	<code>OR-0 ... OR-5</code>	The claimed level. Verifiers compute the verified level (§8) and MUST report both.
<code>privacy_profile</code>	object	§5. Required on every receipt.
<code>predicate_manifest</code>	array	Every predicate present MUST be declared; every declared predicate absent MUST carry an <code>omission_reason</code> (§4.1).
<code>predicates</code>	object	Keyed by registered predicate name.
<code>limitations</code>	string[] ≥ 1	The bounded-claims text. Verifiers MUST surface it.
<code>extensions</code>	object	Namespaced (<code>vendor.name</code>), non-normative. Verifiers MUST ignore what they do not understand and MUST NOT change validity on it.
<code>signature</code>	object	<code>algorithm</code> , <code>canonicalization</code> , <code>key_id</code> , <code>value</code> (base64url, no padding), optional <code>countersignatures[]</code> (§12).

The signature covers the canonical bytes of the whole envelope with `signature.value` set to the empty string and `signature.countersignatures` removed. Countersignatures cover the same bytes and are appended by log operators, witnesses, time authorities, reviewers or assessors.

3. The transaction graph and event boundaries

A transaction is a directed acyclic graph of receipts. Verifiers of a graph MUST check that every parent named is present (or declared external), that all receipts name one root, that every receipt is individually valid, and MUST report the **weakest verified level in the graph** as the level of the transaction. A chain is only as strong as its least-witnessed link.

3.1 Boundary rules

BOUNDARY	THE EVENT IS...	RULE
<code>request-response</code>	one request and the response it produced	Default for chat, API and IDE.

BOUNDARY	THE EVENT IS...	RULE
agent-action	one tool call, delegation hop or side-effecting action	One receipt per action; <code>runtime.child_receipt_ids</code> on the parent names them.
streaming-segment	one segment of a stream (voice, token stream, live agent)	<code>transaction.segment</code> carries <code>index</code> , of when known, the <code>batching_profile</code> and <code>window_ms</code> . A stream MUST close with an <code>aggregate</code> receipt.
batch	one item of a batch run	<code>sequence</code> is the item index. A batch MUST close with an <code>aggregate</code> .
aggregate	a roll-up of segments or items	MUST name every aggregated receipt in <code>parent_receipt_ids</code> or declare <code>transaction.dropped_events_declared: true</code> with the count in <code>extensions</code> .

3.2 Streaming and voice batching profile

Voice and streaming interfaces MUST NOT emit one receipt per token. They MUST choose one `batching_profile` — `per-turn`, `per-utterance`, `time-window` (with `window_ms`), `token-window` or `per-action` — declare it in every segment, keep the same profile for the whole stream, and emit a closing `aggregate` receipt whose `ended_at` is the stream's end. The user-facing receipt identifier for a voice interaction is the aggregate's `receipt_id`, spoken or written on request (§10).

3.3 Delegation

An agent that delegates to another agent emits an `agent-delegation` receipt naming the delegate in `identity.agent` and increments `transaction.delegation_depth`. The delegate's receipts name the delegation receipt as parent. The human principal's mandate (§4.4) is inherited by reference (`mandate.mandate_ref`) down the chain and MUST NOT widen at any hop; a receipt at depth n with a broader scope than its parent is valid syntax but a policy failure the verifier SHOULD flag.

4. Predicates

Each predicate is versioned independently (`type` + `version` in the manifest). Verifiers MUST accept any registered minor version and MUST reject a critical predicate at an unknown major version.

4.1 The manifest and omission reasons

The four **critical** predicates are `transaction`, `policy`, `runtime` and `contestability`. A receipt that omits any of them MUST say why with an `omission_reason` (`not-applicable`, `not-collected`, `withheld-privacy`, `withheld-legal`, `withheld-security`, `unavailable-outage`, `deferred-to-parent`, `deferred-to-aggregate`). Such a receipt is still valid but the verified level is capped at OR-1: signed, not complete. A predicate present but undeclared, or declared-absent without a reason, makes the receipt invalid.

4.2 `transaction` 1.0 — how the event was cut

`interface` (required; §10), `boundary_rule`, `segment`, `id_carrier`, `delegation_depth`, `dropped_events_declared`.

4.3 `identity` 1.0 — who acted, on whose behalf, with what

`principal_binding_mode` (required: `none`, `pseudonymous`, `authenticated-ref`, `collective`), `principal_ref` (a pseudonym or pointer — never a stable user id, e-mail, IP address, exact location or capability token; the reference verifier rejects values that look like one), `operator_id`, `agent{id, card_ref, workload_identity}`, `model{ref, version, bom_ref, weights_commitment}`, `tool_ids[]`. This is the one place human, workload, agent and model are bound to the same event.

4.4 `mandate` 1.0 — what was authorised

`scheme` (required: `plain-words-rule`, `ap2-intent`, `ap2-cart`, `mastercard-verifiable-intent`, `visa-tap`, `acp-allowance`, `oidc-consent`, `none`), `within_mandate` (required: `yes`, `no`, `not-assessed`), `scope`, `limits`, `expiry`, `mandate_commitment`, `mandate_ref`, `community_authority_ref`. External signed mandates are referenced or committed to, never copied. `within_mandate: no` is an honest receipt of a breach, not an invalid receipt.

4.5 policy 1.0 — which gate ran and what it decided

`policy_id`, `version`, `decision` (`allow`, `constrain`, `hold`, `escalate`, `deny`), `enforcement_point` (`pre-action`, `in-flight`, `post-action`, `review`) — all required; `policy_commitment`, `tier`, `controls[]`{`id`, `vocabulary`, `outcome`, `evidence_ref`}, `human_in_loop`, `risk_class`, `jurisdiction_refs[]`. A control listed with `outcome: pass` is a claim that it executed with that outcome — it says nothing about whether the control is adequate.

4.6 runtime 1.0 — what was computed, where

`content_included` MUST be `false`. `input_commitment`, `output_commitment` (\$5), `counts`{`input_tokens`, `output_tokens`, `tool_calls`, `latency_ms`}, `environment`{`attestation`, `attestation_ref`, `region`}, `otel`{`trace_id`, `span_id`}, `child_receipt_ids[]`. Attestation is environment-level evidence (which binary, which enclave); it never says what was answered.

4.7 provenance-disclosure 1.0 — what left, how it was marked

`ai_disclosed`, `output_kind` (required), `disclosure_channel`, `manifest`{`scheme` (`c2pa` | `iptc` | `china-reference-number` | `none`), `manifest_commitment`, `reference_number`}, `accessibility`{`languages`, `formats`}. Text, code and voice — most of what generative AI emits — carry no asset manifest; the receipt is their provenance.

4.8 witness 1.0 — independent registration

Required above OR-2 (\$6): `log_operator`{`id`, `kind`, `service_ref`}, `log_checkpoint`{`tree_size`, `root_hash`, `checkpoint_signature`}, `inclusion_proof`{`leaf_index`, `hashes`, `format`}, `consistency_proof`, `witnesses[]`{`id`, `observed_at`, `cosignature`}, `cross_log_anchor`, `observed_at`, `equivocation_status` (required: `not-observed`, `suspected`, `confirmed`).

4.9 contestability 1.0 — notice, explanation, challenge, review, remedy

Replaces the v0.1 `complaint_ref` pointer with an object a person can act on: `notice`{`given`, `channel`, `languages`, `accessible_formats`}, `explanation`{`available`, `ref`, `kind`, `legal_basis`}, `challenge`{`available`, `route_ref`, `deadline`, `cost`, `representative_allowed`}, `human_review`{`available`, `reviewer_authority` (`override` | `recommend` | `none`), `reviewer_independent`, `sla_hours`}, `remedy`{`types[]`, `collective_redress`, `escalation_ref`}, `case_id`, `outcome_receipt_ids[]`. Challenge, review and remedy are themselves receipts (`transaction_type` `challenge`, `review`, `remedy`) that name the contested receipt as parent, so the whole life of a dispute is one graph. Human review "available" with `reviewer_authority: none` is reported by verifiers as a warning: a reviewer who cannot change the outcome is not review.

4.10 legal-evidence 1.0 — travelling as evidence (optional profile)

`jurisdiction_profile` (`EU-eIDAS-QTSA`, `US-FRE-901`, `CN-online-litigation`, `UK-CPR-PD57AD`, `generic`), `collection_method`, `collector_identity`, `timestamp_assurance` — all required when present; `chain_of_custody[]`, `verifier_version`, `evidence_export_manifest`, `retention_until`. The profile says what was done, never what a court will accept. It is not legal advice and a receipt carrying it MUST add that to `limitations`.

4.11 community-authority 1.0 — collective authority (extension)

`authority_ref`, `consent_basis` (`fpic`, `community-protocol`, `delegated`, `not-applicable`), `use_restrictions[]`, `stewardship_contact_ref`, `review_required_before_disclosure`. Drafted under the CARE principles with — and only with — the Indigenous and community partners named in `governance/COALITION-PLAYBOOK.md`; nothing here ever puts traditional knowledge, sacred material or community governance records in a public log.

5. Privacy profile and threat model

Every receipt carries `privacy_profile`{`profile`, `commitment_scheme`, `linkability_scope`, `metadata_minimization`, `reidentification_risk_assessment_ref`, `disclosure_authority[]`}.

Rules:

1. **Content-free by construction.** No predicate carries prompts, outputs, weights, personal data or free text about a person. `runtime.content_included` is a schema constant `false`.

2. **No plain hashes.** Every commitment uses `salted-sha256`, `hmac-sha256` or `pedersen`. The salt or key never enters the receipt or the log; it is delivered out of band to whoever `disclosure_authority` names. A plain hash of a short prompt, an e-mail address or a menu option is guessable and is therefore forbidden; a receipt containing one is invalid.
3. **Public logs hold no stable identifiers.** Nothing registered with a log operator may contain a stable user id, IP address, exact location, device identifier or capability token. `identity.principal_ref` is a per-transaction or per-session pseudonym at most (`linkability_scope`).
4. **Metadata is minimised.** Counts, latencies and regions are rounded or bucketed where the reidentification risk assessment says so; `reidentification_risk_assessment_ref` points to that assessment for OR-3 and above.
5. **Content-free is not anonymous.** Graph shape, timing and counts leak. Operators MUST say so in `limitations` and MUST NOT describe receipts as anonymous.
6. **Disclosure is authorised, not implied.** `disclosure_authority` names roles or authorities, never persons. Opening a commitment for a regulator, a court, a reviewer or the principal is a separate act that SHOULD itself produce a `review` receipt.

The threat model considered: linkage across transactions by a log reader; dictionary attacks on commitments; timing correlation between logs; an operator equivocating between the log shown to users and the log shown to auditors (§6); a delegate widening a mandate; a reviewer without authority laundering a decision as "human-reviewed"; and a registry steward or assessor with a commercial interest in the outcome (§9).

6. Witnessing, logs and equivocation

- **OR-2** requires registration in an append-only Merkle log with a checkpoint and an inclusion proof (RFC 6962 style, or an RFC 9942 COSE receipt). The log MAY be operated by the issuer.
- **OR-3** requires a log operator that is **not** the issuer, and at least one independent witness co-signing checkpoints. Verifiers SHOULD fetch a fresh checkpoint and a consistency proof from the witnessed size.
- **Equivocation** — two checkpoints of the same log at the same size with different roots, or an inclusion proof that fails against a witnessed checkpoint — sets `equivocation_status` to `suspected` (one observer) or `confirmed` (two independent observers). A receipt whose log is under suspected or confirmed equivocation is **frozen at OR-2** for every verifier until the log operator publishes an `incident` receipt and the witnesses re-sign. Verifiers MUST NOT report OR-3 or higher on a frozen log.
- **No single route.** At OR-3 and above no one vendor may be the only permitted log, witness, verifier, time service or key-discovery route. Profiles that name a vendor are non-conformant.
- **Backfill.** Receipts registered late (outage) keep `issued_at` as signed and carry the log's `observed_at`; the gap is visible, not hidden.

7. Contestability

A receipt that records a consequential decision (`transaction_type` `policy-decision`, `output-delivery` or `human-review` with a `policy.risk_class`) at OR-2 or above MUST carry a `contestability` predicate in which notice was given, an explanation is available, a challenge route exists, and human review — where offered — names a reviewer with `override` or `recommend` authority. Remedies MUST be named from the registered list; `compensation-referral` means a referral exists, not that compensation is owed. `collective_redress: true` means a representative may challenge on behalf of a class of affected people. The Public Interest Council (governance) owns this predicate's evolution; technical bodies may not narrow it.

8. Assurance levels

The issuer **claims** a level. The verifier **computes** the level the evidence supports and MUST report both. The reference verifier's rules:

LEVEL	NAME	WHAT MUST BE TRUE	VERIFIER CAPS TO THE LEVEL BELOW WHEN...
OR-0	Unverified export	Well-formed envelope; signature absent or unverified	—
OR-1	Issuer signed	Signature verifies against a discoverable key; all four critical predicates present	a critical predicate is omitted (with reason)
OR-2	Operator logged	OR-1 + <code>witness</code> with checkpoint and inclusion proof (issuer-run log allowed)	no inclusion proof

LEVEL	NAME	WHAT MUST BE TRUE	VERIFIER CAPS TO THE LEVEL BELOW WHEN...
OR-3	Independently logged	OR-2 + log operator ≠ issuer + ≥ 1 independent witness + no equivocation	operator runs the log; no witness; equivocation suspected or confirmed (frozen at OR-2)
OR-4	Independently assessed	OR-3 + an assessor (≠ issuer, ≠ log operator) with a current assessment on a public registry	no registry record, or assessor is the issuer
OR-5	Public-interest accountable	OR-4 + a Public Interest Review Panel record covering this system and profile	no review record

OR-4 and OR-5 cannot be established from the receipt alone; they require a registry lookup the verifier performs or is handed. A verifier without registry access **MUST** report OR-3 at most and say why. OR levels describe the **evidence chain**, never the AI system's quality; they are deliberately not OVERT AAL levels and are not borrowed from any certification.

9. Roles and separation

ROLE	DOES	MUST NOT	MUST DISCLOSE
Operator	Emits receipts for systems it runs; keeps salts; answers challenges	Operate the sole log or act as assessor for its own systems above OR-2; describe receipts as certification	Beneficial ownership; commercial ties to log, assessor, insurer
Log operator	Registers receipts; publishes checkpoints; supports witnesses and consistency proofs	Alter or reorder entries; be the issuer's affiliate at OR-3+; be the only route	Availability and consistency metrics; incidents; ownership
Assessor	Samples receipts and controls without content access; publishes methodology and negative findings	Assess its own technology, related log, controlled operator or underwriting client; be qualified by a sponsor	Methodology; conflicts; abstentions
Registry steward	Publishes keys, profiles, assessor and review records	Sell trust status; hold a commercial interest in an issuer it lists; be the sole steward long-term	Funding; governance; change log
Reviewer / remediator	Issues review and remedy receipts	Claim authority it lacks (reviewer_authority)	Independence from the operator
Verifier	Anyone	—	—

The AiGovOps Foundation may act as convener, reference implementer and initial registry steward. It **MUST NOT** be the sole long-term registry steward, assessor qualifier, notary operator or assurance issuer, and it never grades its own receipts.

10. Interface profiles

Same envelope, same predicates; what changes is how the id is carried and how the person sees it.

INTERFACE	ID_CARRIER	THE PERSON SEES	BOUNDARY
Chat / web	response-header + visible affordance	a receipt link under every answer	request-response
API	AI-Receipt response header; request may carry AI-Mandate	the SDK prints it; maps 1:1 to an OTel span	request-response
Voice	spoken on request; transcript	"say 'receipt'" → the aggregate id	streaming-segment + aggregate
Agent-to-agent	message-metadata ; nested receipts per hop	the root receipt for the human principal	agent-action
IDE / coding agent	git-trailer (One-Receipt: <id>)	in the commit	agent-action
Browser extension	message-metadata	the extension's panel	request-response
Embedded / on-device	device-store ; uploads when online	Settings → receipts	request-response
Commerce	cart-mandate (AP2 / Verifiable Intent hash in mandate)	the merchant receipt cites it	agent-action
Batch	none (aggregate id in the run record)	the aggregate	batch + aggregate

11. Legal-evidence profile

Optional. Adds `legal-evidence` (§4.10) and requires `clock_source` other than `issuer`, a `chain_of_custody` starting at the operator, and an `evidence_export_manifest` listing every receipt, key, checkpoint and proof in the export with the `verifier_version` used. Jurisdiction profiles are maintained by legal-evidence specialists in the coalition and are descriptive. Nothing in this profile is legal advice; `limitations` MUST say so.

12. Canonicalisation, signatures and algorithm agility

- Canonical bytes: JSON with sorted keys, no insignificant whitespace, UTF-8, no floating-point numbers (the v0.2 profile); a full RFC 8785 (JCS) canonicaliser and a CBOR-CDE profile are v0.3 gates and MUST produce byte-identical signatures across implementations before either is normative.
- Algorithms: `Ed25519` (default), `ES256`, `ML-DSA-65`, and hybrid `Ed25519+ML-DSA-65`. Verifiers MUST refuse algorithms not in the registry and MUST NOT downgrade.
- Key discovery: `did-web`, `did-key`, `jwks`, `x509`, `scitt-issuer`, `out-of-band`. Key rotation and revocation records live with the registry steward; a receipt signed after its key's revocation time is invalid.
- Countersignatures append; they never replace the issuer's signature.

13. Conformance layers

1. **Syntax** — emits and verifies envelopes that pass the schema, the reference verifier and every vector in `testkit/vectors` with identical verdicts.
2. **Interoperability** — verifies receipts emitted by at least one other independent implementation, and registers with at least one log it does not operate, at a public interoperability event.
3. **Accountability outcomes** — a pilot reports, against pre-registered metrics, whether receipts shortened time-to-answer for audits, incidents, disputes and vendor transitions, whether people could exercise a challenge, and what it cost a small implementer. Layer-3 results, including negative ones, are published.

An implementation may claim "One Receipt v0.2 syntax-conformant" only after layer 1 and never "certified". No conformance layer says anything about the AI system.

14. Registries and extensions

Registered here and maintained by the registry steward: predicate types and versions; `transaction_type`; `boundary`; `omission_reason`; signature algorithms; `key_discovery`; `id_carrier`; mandate schemes; control vocabularies; jurisdiction profiles; remedy types. Extensions use `extensions.<namespace>.<name>` with a registered namespace (`aigovops`, `glacis`, `scitt`, ...) and never affect validity.

The delta matrix in `spec/delta-matrix.md` records, field by field, what One Receipt takes from and gives to SCITT, OVERT, OpenTelemetry GenAI, C2PA, AP2 / Verifiable Intent, AIUC-1, W3C VC / DID, and the EU AI Act logging standard prEN 18229-1. Mappings remain non-normative until accepted by the relevant body.

15. What changed from v0.1

- Scope and bounded-claims section leads; the "nothing exists" framing, insurance-premium claims, "anonymous", AAL borrowing and "explanation-ref as proof" are gone.
- Transaction graph: `event_id`, `root_receipt_id`, `transaction_type`, `sequence`, `boundary`, `started_at/ended_at`, `clock_source`; streaming/voice batching profile; delegation rules.
- Ten versioned predicates with a manifest and omission reasons; `witness`, `contestability`, `legal-evidence`, `community-authority` are new; `complaint_ref` is replaced by the contestability object.
- Privacy profile with a threat model; plain hashes and stable identifiers are rejected by the verifier.
- Assurance OR-0...OR-5 with verifier-computed levels and the equivocation freeze.
- Four separated roles with must-nots and disclosures; the Foundation's own limits stated.
- Algorithm agility and countersignatures; conformance in three layers; registries.

Delta matrix — what One Receipt takes from, gives to, and leaves alone

Non-normative until the named body accepts a mapping. Dates verified 13 September 2026 (research memos in the [practice repo](#), [docs/reference/research/](#)). This is the document the coalition's standards liaisons are asked to review first (playbook, partner group 3).

ADJACENT WORK (STEWARD, STATUS)	ONE RECEIPT TAKES	ONE RECEIPT ADDS	STAYS OUT OF SCOPE	PROPOSED CONTRIBUTION ROUTE
IETF SCITT — RFC 9943 architecture, RFC 9942 COSE receipts (Jun 2026)	Transparency service model; checkpoint, inclusion and consistency proofs; <code>rfc9942-cose-receipt</code> as an <code>inclusion_proof.format</code>	A registered statement profile for AI transaction events (the envelope as the signed statement); witness co-signatures; equivocation freeze semantics	Log internals, transport	Internet-Draft "AI Transaction Statement Profile" co-authored with SCITT editors and one log operator
OVERT 1.1 (Glacis, 11 Jun 2026)	Per-action control evidence; <code>controls[].vocabulary: overt</code> ; the idea of an Independent Attestation Provider	Cross-vendor envelope; SCITT registration; human mandate; disclosure; contestability object; separation of runtime seller from assessor qualifier	OVERT domains and AAL definitions (not borrowed; OR levels describe the evidence chain only)	Registered profile one-receipt.v0 under Agentic-Extended; joint SCITT draft
OpenTelemetry GenAI semantic conventions (v1.42, Development)	<code>gen_ai.*</code> names for model, tokens, tools, agents; <code>runtime.otel.trace_id/span_id</code>	Signing and registration of the span's claims as a receipt; a mapping table <code>gen_ai.*</code> ↔ predicate fields	Stability of the conventions; sampling	PR to semantic-conventions-genai with the mapping table
C2PA 2.3 / IPTC 2025.1	Asset manifests for files; <code>provenance-disclosure.manifest.scheme: c2pa</code>	A receipt id assertion so a signed file points back to the event; provenance for text, code and voice, which carry no manifest	Manifest format	Assertion type proposal to C2PA TWG
AP2, Mastercard Verifiable Intent, Visa TAP, OpenAI/Stripe ACP	Signed intent/cart/payment mandates unchanged (<code>mandate.scheme</code>)	What the model did between intent and cart; <code>within_mandate</code> as an honest breach record; delegation inheritance	Payment rails	Liaison note; test vectors using AP2 sample mandates
AIUC-1 (AIUC; quarterly; insurer-priced; UiPath a founding contributor)	<code>controls[].vocabulary: aiuc-1</code> ; the periodic-certificate model	Per-call evidence that a certified control ran ("certificate-to-receipt link"); an assessor role that is not the standard's editor or the underwriter	Certification, insurance pricing	Proposal: certified agents emit receipts; shared control-id vocabulary
W3C VC 2.0 / DID 1.1; SPIFFE / WIMSE; A2A Agent Cards; OpenID AAIM	Subject, workload and agent identifiers by reference	Binding human + workload + agent + model to one event without personal identifiers	Identity issuance	Use-case submission to ITU FG-TIDA (first meeting Nov 2026)
CycloneDX 1.7 ML-BOM; SPDX 3.0.1 AI; OpenSSF Model Signing	<code>identity.model.bom_ref</code> , <code>weights_commitment</code>	The link from a model's bill of materials to the events it served	BOM formats	None needed; reference only

ADJACENT WORK (STEWARDS, STATUS)	ONE RECEIPT TAKES	ONE RECEIPT ADDS	STAYS OUT OF SCOPE	PROPOSED CONTRIBUTION ROUTE
RATS (RFC 9334); Confidential Space; PCC	<code>runtime.environment.attestation</code> references	Honest scoping: attestation is environment-level, never answer-level	Attestation formats	None; reference only
EU AI Act as amended by (EU) 2026/1744 — Art. 12 logging (prEN 18229-1 at Enquiry), Art. 26(6) six-month floor, Art. 50 (live 2 Aug 2026), Art. 73 incidents, Art. 86 explanation, Annex III 2 Dec 2027	Retention floor; disclosure duty; explanation right; incident duty	A content-free log record pattern; the receipt id as the Art. 73 incident anchor; <code>contestability.explanation.legal_basis</code>	Legal interpretation	Comment on the prEN 18229-1 enquiry; note to the AI Office sandbox
Colorado SB 26-189; California SB 942; Korea AI Basic Act; China labelling rules	Disclosure, labelling and explanation duties; China's per-output reference number (<code>manifest.reference_number</code>)	One field set that satisfies each duty's evidence need	Compliance determinations	Regulator observers in the coalition (playbook group 10)
NIST AI RMF / AI 600-1; ISO/IEC 42001, 42005, 42006; CSA AICM 1.1	Control vocabularies for <code>controls[].vocabulary</code>	Per-event evidence a management-system audit can sample	Management-system certification	Use-case submission to the NIST AI Agent Standards Initiative
OECD AIM; AIID; AIAAIC; FMF incident sharing	Incident taxonomies	<code>incident</code> receipts that carry a hash and inclusion proof instead of prose alone	Incident databases	Liaison note
AiGovOps Foundation projects (Beacon, Umbrella, Lantern, aigovops, Replay, prompt-studio, practice)	Ed25519/JCS signing; UCID control ids; append-only log; the corpus as test vectors; the practitioner ladder	The shared envelope; see <code>adapters/</code> for each project's delta	—	This repository

Terminology collisions to resolve with liaisons: "receipt" (RFC 9942 uses it for the log's proof; One Receipt uses it for the signed statement — the SCITT draft will say *statement* and *transparency receipt* precisely); "attestation" (RATS vs OVERT); "mandate" (AP2 vs plain-words rule); "witness" (SCITT vs Sigstore).

One Receipt — Master Plan

Complete product, standards, open-source and global-coalition plan. Version 0.2, 14 September 2026. Owners: Bob Rapp and Ken Johnston, AiGovOps Foundation. Status: **for decision** (the twelve decisions at the end).

This plan folds three inputs into one place: the v0.1 whitepaper review (`docs/WHITEPAPER.md`), the v0.2 recommended amendments (now the spec, `spec/ONE-RECEIPT-SPEC.md`), and the coalition invitation and funding playbook (`governance/COALITION-PLAYBOOK.md`).

1. Executive summary

Every AI standard in the field holds one piece of the evidence problem — the organisation, the quarterly certificate, the per-decision control, the file's provenance, the shopping mandate, the log, the legal duty — and none joins them into one verifiable record of one transaction that a stranger can check, a person can challenge, and a regulator can inspect without trade secrets. One Receipt is that record: a content-free, signed, chained envelope with ten versioned predicates, six assurance levels the verifier computes rather than trusts, four separated roles, and a governance model in which public-interest participants are paid and can bind.

The program is built to avoid two predictable failures: **vendor capture** (no operator, log provider, assessor or insurer buys control of the protocol, the assurance ladder, the registry or the conflict process) and **unfunded participation** (civil society, affected communities, accessibility specialists, Global South and Indigenous partners are compensated, not invited to donate the labour that gives the coalition legitimacy).

The Foundation's role is convener, first implementer and teacher. It issues no standard, grades no receipts, and is not the long-term sole registry steward, assessor qualifier, notary operator or assurance issuer.

2. Strategic thesis

1. **Procurement, not goodwill, drives adoption.** Buyers who can specify "portable evidence at OR-2 with contestability" in a contract turn a protocol into a market requirement. The plan leads with three buyers in the founding cohort.
2. **Insurance and certification need per-call evidence they cannot produce themselves.** AIUC-1 says an agent passed last quarter; a receipt says control A006 ran on this call. The program offers that link and makes no premium claims.
3. **The standards bodies want mappings and running code, not a rival stack.** The SCITT statement profile, the OTel mapping table, the C2PA assertion and the AP2 test vectors are the contributions; the delta matrix is the first thing liaisons see.
4. **Legitimacy precedes vendors.** Public-interest, regional and Indigenous partners are seated and paid before the first commercial sponsor is announced.
5. **The small implementer is the test.** If OR-1 takes more than an afternoon for a two-person team, the core is too big.

3. The framework

Principles, personas, lifecycle (Declare · Gate · Prove · Verify · Contest · Improve), eighteen domains, capabilities and the five-level maturity model are in `docs/FRAMEWORK.md`.

4. Business plan and funding safeguards

Eighteen-month budget target: \$3.0M–\$5.0M, deliberately diversified. Allocation: open technical core and security 25%; public-interest participation 20% minimum (protected line); independent research and evaluation 20%; pilots and adoption 15%; governance, legal and registry operations 10%; reserves and incident response 10%.

Revenue guardrails (binding): no single contributor above 15% of annual unrestricted revenue; no commercial sector above 35%; at least 20% ring-fenced for compensated public-interest participation; at least 20% for independent evaluation and security/privacy research; every contribution above \$10,000 publicly disclosed with range, restrictions and conflicts; restricted funding never determines a technical conclusion, assessor qualification, conformance outcome, public-interest decision or publication; an annual transparency report with revenues, expenses, in-kind, participation, conflicts, outcomes and unresolved dissent.

Funding requests by partner group (cash asks for commercial parties, funding *offers* for public-interest parties) are in the playbook: large AI providers \$250k–\$750k; cloud/security platforms \$250k–\$500k; buyers \$100k–\$300k; assurance firms \$75k–\$250k; insurers \$100k–\$300k; standards bodies no cash ask; civil-society council members \$25k–\$75k grants; Indigenous governance bodies \$50k–\$150k partnership grants; universities \$50k–\$250k project grants; Global South research leads \$75k–\$300k; small implementers no fee plus \$5k–\$25k microgrants.

5. Three-year outcomes

HORIZON	OUTCOME
Year 1	v1.0 core spec ratified by the Technical Incubator with Public Interest Council sign-off; Python and TypeScript SDKs; offline verifier; two independent implementations and two independent log/witness paths at a public interop event; three pilots (one public sector) with pre-registered evaluations; the SCITT Internet-Draft adopted for discussion; the Foundation's own projects emitting and reading receipts
Year 2	OR-4 assessor pool with public methodology and at least one negative finding published; procurement clauses used in one real contract; regional chapters in three regions with ten languages; the OTel mapping and C2PA assertion accepted or formally declined with reasons
Year 3	Registry stewardship transferred out of the Foundation to a multi-party steward; OR-5 public-interest review operating; layer-3 outcome evidence published for every pilot; the coalition's annual transparency report in its third edition

6. Governance

Bodies, decision rules and founding roles are in [governance/CHARTER.md](#): a Governing Board (mission, fiduciary, host relationship; cannot approve a member's conformance claim), a Technical Steering Committee / Technical Incubator (rough consensus, no member veto), a Public Interest Council (binding review over privacy, accessibility, contestability, affected-community rights, data sovereignty, conflicts), an Adoption Council / Adoption and Pilot Network (recommends, never certifies its own pilots), an Independent Appeals Panel, and a Standards Liaison Forum. Conflict rules are in [governance/CONFLICT-OF-INTEREST.md](#); funding rules in [governance/FUNDING-AND-INDEPENDENCE.md](#).

7. Product requirements (PRD)

Functional. Emit, sign, chain, register, verify, export; verify a graph; compute the verified level; produce the plain-language receipt view in ten languages; route challenge, review and remedy as receipts; run the conformance vectors; adapters for SCITT, OVERT, OTel, C2PA, AP2 and the Foundation projects.

Non-functional. OR-1 emission adds < 5 ms p50 and no network call; verifier runs offline; receipts ≤ 8 KB typical; no content, no stable identifiers; every result carries limitations; algorithm agility; twelve-month deprecation for any breaking change; accessibility (WCAG 2.2 AA) for every user-facing view.

Success metrics. Time-to-answer for audit, incident, dispute and vendor-transition questions in pilots (pre-registered baseline vs. with receipts); share of consequential decisions with a contestability predicate; challenge completion rate and time to human review; small-implementer cost to OR-1 in person-hours; number of independent implementations passing the vectors; number of independent log/witness paths; published negative findings.

FAQ (the honest answers). *Does a receipt prove the AI was right?* No. *Is it anonymous?* No — content-free, with a threat model. *Is it a certification?* No. *Does it lower my premium?* Nobody may say so without independent evidence. *Is it admissible?* The legal-evidence profile says what was done; a court decides. *Who grades the Foundation's receipts?* Not the Foundation.

8. Technical architecture

Twelve components: (1) envelope and predicate schemas; (2) canonicaliser and signer; (3) key discovery and rotation; (4) policy gate adapter; (5) commitment service (salts out of band); (6) log client (SCITT / Rekor / Merkle); (7) witness client and equivocation monitor; (8) verifier (single and graph); (9) contestability router; (10) evidence exporter (legal-evidence profile); (11) registry client (assessor, review, key records); (12) conformance test-kit. Trust boundaries: operator ↔ log operator ↔ witness ↔ assessor ↔ registry steward; salts never cross the operator boundary except by authorised disclosure. Detail in [docs/ARCHITECTURE.md](#) and the spec.

9. Open-source design

Repository portfolio (this repository seeds them; split when a second maintainer exists): [one-receipt-spec](#) (this spec, schemas, registries, delta matrix), [one-receipt-sdk-python](#), [one-receipt-sdk-ts](#), [one-receipt-verifier](#) (offline CLI and web verifier), [one-receipt-testkit](#) (vectors, interop harness), [one-receipt-log-lab](#) (a small SCITT-style log with witnesses for

pilots and anti-equivocation drills), [one-receipt-adapters](#) (SCITT, OVERT, OTel, C2PA, AP2, Foundation projects), [one-receipt-governance](#), [one-receipt-learning](#), [one-receipt-pilots](#).

Licensing. Apache-2.0 code; CC BY 4.0 specifications and documents; DCO sign-off; royalty-free patent commitments from contributing organisations for normative text; trademarks separately governed ([governance/IP-POLICY.md](#)).

Engineering standards. Public issues and PRs; two non-author approvals for normative changes; security review for cryptographic changes; Public Interest Council review for privacy and contestability changes; 30-day RFC for breaking changes; CI runs lint, tests, vectors, schema meta-validation, TypeScript, the 360-requirement check and links.

10. Development plan, test plan and PMO

Phases are in [docs/ROADMAP.md](#) with gates G0–G7 in [governance/RELEASE-GATES.md](#). The test plan has three layers matching conformance: syntax (schema + vectors), interoperability (cross-implementation, cross-log), and accountability outcomes (pre-registered pilot metrics). The PMO runs a fortnightly public status, a public risk register, and the annual transparency report.

11. Global rollout

Phase 0 (now): the Foundation's own projects emit and read receipts; the café teaches it. Phase 1 (months 1–6): founding cohort of 18–24 balanced parties; two independent implementations; the first interop event. Phase 2 (months 7–12): three pilots across sectors and regions; procurement language in use; regional co-chairs; ten languages. Phase 3 (months 13–18): assessor pool; registry stewardship transfer plan; OR-5 review operating. At least half of non-vendor seats outside North America and the EU.

12. Standards strategy

Order of outreach: existing adjacent standards and open-source communities first (reconcile, do not duplicate), then public-interest and regional partners, then implementers and log witnesses, then buyers, then researchers, then auditors/insurers/regulators, then additional sponsors. Contributions: the SCITT statement profile draft; the OVERT profile; the OTel mapping table; the C2PA assertion; AP2 test vectors; the NIST AI Agent Standards Initiative and ITU FG-TIDA use cases; comments on prEN 18229-1. No claim of endorsement, adoption or standards status without a written decision.

13. Marketing and education

The story is told from the café: a person asks for a receipt and gets one. Never a logo wall; never "certified"; never "anonymous"; never a premium claim. The practitioner program ([docs/PRACTITIONER-PROGRAM.md](#)) is the education plan — OR-100 to OR-600, each level one hour of practice that returns the practitioner to the community.

14. Risks

Vendor capture (mitigated by caps, seats and conflict rules); audit-washing (bounded claims in every artefact; negative findings published); privacy leakage through metadata (threat model, risk assessment above OR-2); equivocation and log outages (witnesses, freeze, backfill rules); complexity creep (the small-implementer test at every gate); standards rejection (mappings are non-normative, contributions are narrow); legal-evidence over-claiming (profile is descriptive; limitations mandatory); Foundation over-reach (its must-nots are in the spec).

15. Launch blockers

The coalition launches only when: a published charter, contribution policy, IP policy, conflict register, code of conduct and decision process exist; paid public-interest and regional participants are in the first cohort before the announcement; no commercial contributor above 15%; two independent implementations and two independent log/witness paths committed to the first interop event; one buyer with a real procurement or audit-evidence use case; one research partner with a pre-registered evaluation; the public delta matrix published; and launch language with no unsupported claim about compliance, safety, fairness, admissibility, premium reduction or certification.

16. Twelve immediate executive decisions

1. Name: **One Receipt** (working); repository [One-ai-Receipt-aigovops-foundation](#) — confirm or rename.
2. Adopt the v0.2 spec as the incubation baseline and freeze v0.1.
3. The Foundation as neutral convener and initial registry steward with a written transfer intent — yes/no.

4. Invite Glacis and the OVERT community as proposed inaugural technical contributors under the conflict rules — send now with the delta matrix, or after the SCITT draft exists.
5. Host the working group at the Foundation, or ask the Agentic AI Foundation (Linux Foundation) to host.
6. Fund the Public Interest Council first: approve the protected 20% line and the first four to six paid seats.
7. Choose the three founding buyers and the one public-sector pilot to approach.
8. Which ten corpus cases become the first test vectors (twelve are seeded in `testkit/vectors`).
9. Approve the SCITT Internet-Draft as the first standards contribution and name co-authors to approach.
0. Adopt OR-0...OR-5 as the assurance ladder and decline to borrow AAL levels — confirm.
1. Approve the Foundation-project adoption plan (`docs/ADOPTION.md`) and the Fall release versions it implies.
2. Approve the 18-month budget target and the funding guardrails as binding.

17. Final direction

Build the smallest receipt a stranger can verify; make it a graph; put contestability inside it; pay the people who make it legitimate; contribute every mapping upstream; publish what breaks. Then let procurement do the rest.